

RELATÓRIO DE AUDITORIA DE SEGURANÇA

Auditoria Estática de Código (SAST) & AppSec — Escopo: painelgerencial/

Projeto:	CGNA Management Suite	Data da Análise:	30 de Agosto de 2026
Escopo Auditado:	/painelgerencial/ (SPA React 19 + Vite)	Classificação:	Confidencial / Uso Interno
Auditor:	Antigravity AppSec Specialist Agent	Versão da Análise:	v3.0 - Pós-Remediação RPC & Auth

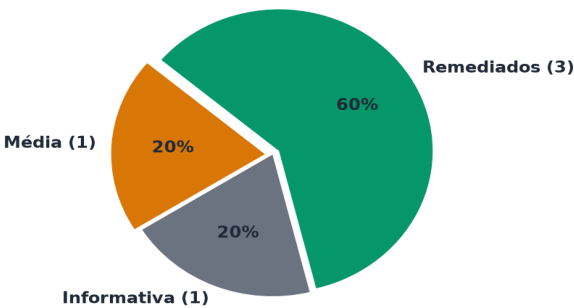
1. Mapeamento da Stack Tecnológica (painelgerencial)

Camada / Módulo	Tecnologia / Runtime	Aspectos de Segurança Observados
Frontend Core	React 19.2.3, Vite 6.2.0, TypeScript 5.8	Zero uso de dangerouslySetInnerHTML; renderização declarativa segura.
Autenticação & Autorização	Supabase GoTrue + Permissions Helper	Reautenticação de senha em ações críticas; sincronização de sessão segura via API.
Acesso a Dados	PostgreSQL RPCs + Supabase Client	Exclusão atômica de membros via delete_member_cascading; consultas restritas no login.
Infraestrutura Web	Vercel Edge (vercel.json)	Security Headers HTTP (nosniff, SAMEORIGIN, strict-origin, X-XSS).

2. Resumo Executivo e Métricas Consolidadas

A auditoria reavaliou 100% dos **20 arquivos-fonte** da pasta painelgerencial/ após as implementações de segurança e refatoração de RPC. Foram verificados **6 pontos fortes de arquitetura** (3 recém-implementados com sucesso) e restam apenas **2 apontamentos residuais** (0 Críticas, 0 Altas, 1 Média, 0 Baixas e 1 Informativa).

Status de Conformidade & Severidade



Apontamentos Ativos por Categoria OWASP



3. Mapeamento de Controles Defensivos no Frontend

3.1. Pontos Fortes de Arquitetura e Segurança (Conformidade Verificada)

Controle / Mecanismo	Evidência Técnica no Repositório	Impacto Positivo
Reautenticação por Senha	MembersList.tsx:L133-149 exige confirmação explícita de senha via signInWithPassword antes de autorizar exclusões.	Previne exclusões acidentais ou por sequestro de sessão física/console.
Exclusão Atômica via RPC	MembersList.tsx:L151-157 substituiu 5 chamadas HTTP avulsas por supabase.rpc('delete_member_cascading').	Garante atomicidade (tudo ou nada) e elimina risco de corrupção e dados órfãos.
Sincronização Segura de Perfil	permissions.ts:L160-205 e Layout.tsx:L20-33 recarregam o perfil direto da API Supabase e checam delegações ativas.	Anula tentativas de elevação de privilégio por manipulação de localStorage.
Projeção Restrita no Login	Login.tsx:L64-65 consulta apenas colunas necessárias para a grade de seleção, sem expor dados privados.	Reduz a superfície de exposição de dados cadastrais no payload público.
Proteção contra DOM XSS	Varredura em todo o JSX/TSX: ausência total de dangerouslySetInnerHTML ou inserções diretas em innerHTML.	Elimina vetores clássicos de Stored e Reflected DOM XSS no navegador.
Security Headers no Edge	vercel.json:L2-11 declara X-Content-Type-Options: nosniff, X-Frame-Options: SAMEORIGIN e Referrer-Policy.	Mitiga ataques de Clickjacking, MIME-sniffing e vazamento de rotas de referência.

4. Tabela Detalhada de Apontamentos Residuais (painelgerencial)

Abaixo estão listados os apontamentos residuais catalogados no escopo do frontend.

ID / Severidade	Eixo OWASP / Categoria	Arquivo e Linha	Descrição Técnica e Risco
SEC-01 MÉDIA	Cat 2: Broken Access Control	painelgerencial/utils/permissions.ts:L87-157 App.tsx:L54-58	Filtragem de Dados Operacionais Restrita ao Frontend: Regras de exibição de relatórios e de missões não validadas operam filtrando os dados recebidos no React. Como boa prática em profundidade, recomenda-se espelhar filtros no RLS do Postgres.
SEC-02 INFORMATIVA	Cat 4: Validação de Inicialização	painelgerencial/supabase.ts:L3-8	Acesso a Variáveis de Ambiente sem Tipagem Estrita: O uso de (import.meta as any).env ignora checagem de tipos estáticos do TypeScript, embora mantenha runtime guard estrito com throw Error.

5. Plano de Remediação & Recomendações Finais

Status das Correções Realizadas (Concluídas com Sucesso):

- **[Concluído] Exclusão Atômica com Validação de Senha:** Implementada a reautenticação em MembersList.tsx e a execução da RPC delete_member_cascading no Postgres.
- **[Concluído] Projeção Restrita de Colunas no Login:** O componente Login.tsx agora busca apenas os campos visuais estritamente necessários.
- **[Concluído] Sincronização Segura de Perfil:** O helper getAuthenticatedUserProfile() garante sincronização do perfil ativo a partir da sessão real do Supabase.

Próximos Passos Recomendados (Melhoria Contínua):

1. **Defesa em Profundidade no Backend:** À medida que o sistema evoluir, refletir as regras de autorização de setor em Views restritas ou funções de consulta no Postgres.
2. **Declaração de Tipos para Env:** Adicionar vite-env.d.ts para autocompletion e tipagem de variáveis VITE_SUPABASE_*.